

DOSSIER D'ARCHITECTURE TECHNIQUE

NEXUS SOC

Conception technique détaillée d'une plateforme SOCaaS souveraine

Auteur : NGUETSA Junior Stéphane Céleste

Établissement : KEYCE Informatique & IA — Yaoundé

Diplôme : Bachelor 3 RSI

Document : Architecture technique — Version 1.0

Sommaire

1. Vue d'ensemble	3
2. Principes directeurs de conception	3
3. Composant 1 — Agent universel léger	3
4. Pipeline de données	4
5. Composant 2 — Moteur SIEM et corrélation	4
6. Composant 3 — UEBA (analyse comportementale)	5
7. Composant 4 — SOAR (réponse automatisée)	5
8. Composant 5 — Portail, LLM Analyst et notifications	5
9. Stockage et souveraineté des données	6
10. Multi-tenant et sécurité de la plateforme	6
11. Déploiement, CI/CD et supervision	6
12. Cartographie MITRE ATT&CK; (extrait)	6

1. Vue d'ensemble

NEXUS SOC suit une architecture en quatre couches : un parc client instrumenté par des agents légers ; un pipeline d'ingestion temps réel ; un cœur analytique hébergé sur un cloud souverain multi-tenant ; des canaux de restitution (portail et notifications).

NEXUS SOC — Architecture générale

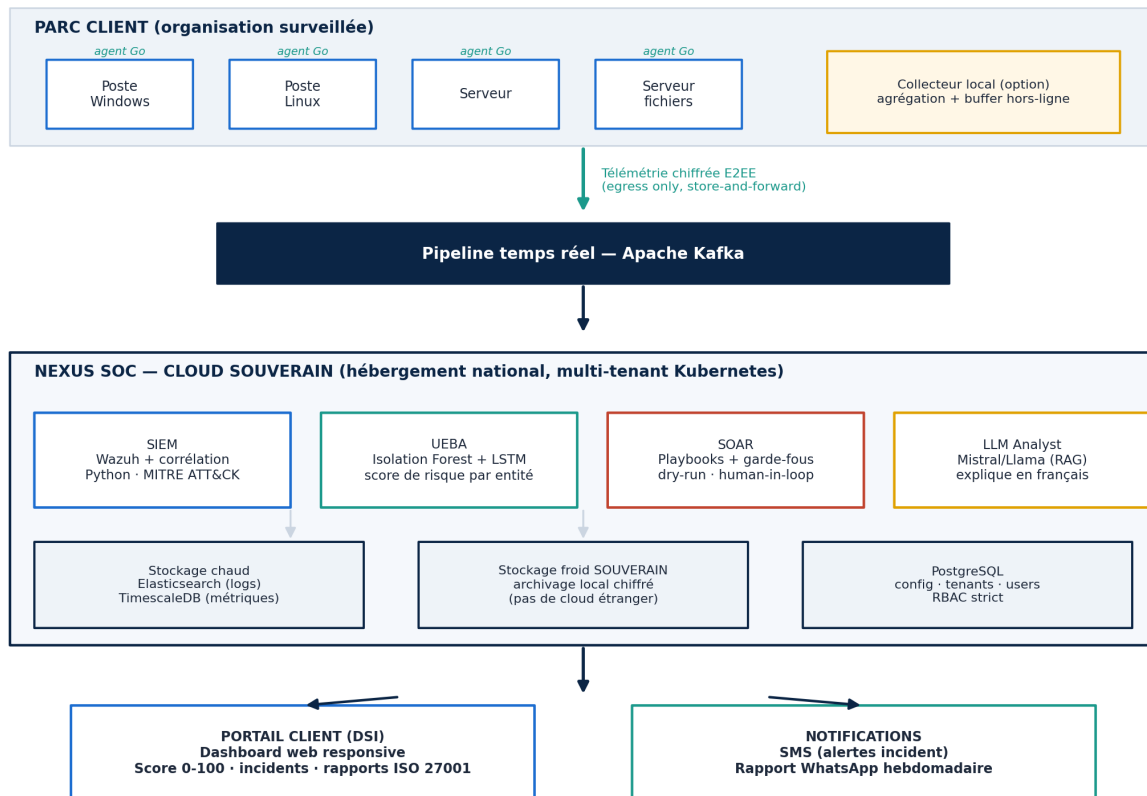


Figure 1 — Architecture générale de NEXUS SOC.

2. Principes directeurs de conception

- **Souveraineté par défaut** — les données sensibles restent sur une infrastructure nationale.
- **Résilience au contexte local** — fonctionnement dégradé sous connectivité intermittente et coupures électriques.
- **Sécurité de la plateforme elle-même** — le SOC est traité comme un actif critique à protéger en priorité.
- **Automation-first, human-in-the-loop** — l'automatisation traite le volume, l'humain tranche les cas sensibles.
- **Approche fondée sur les preuves** — chaque détection est cartographiée (MITRE ATT&CK;) et chaque performance mesurée.

3. Composant 1 — Agent universel léger

Écrit en Go pour produire un binaire unique multiplateforme (Windows/Linux) à faible empreinte. L'agent collecte connexions réseau, processus, modifications de fichiers et événements système, puis transmet une télémétrie chiffrée en flux sortant uniquement.

3.1 Résilience hors-ligne

En cas de perte de connectivité, l'agent met les données en file d'attente locale persistante (store-and-forward) et les rejoue à la reconnexion, sans perte. Il tolère les arrêts brutaux liés aux coupures électriques sans corrompre sa file.

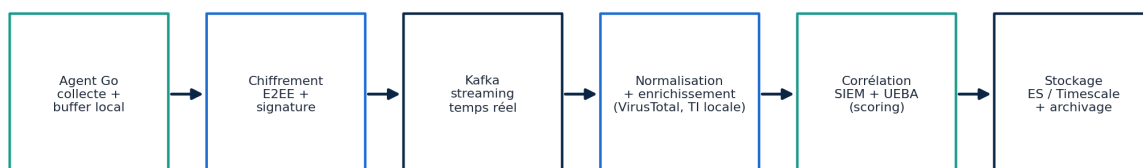
3.2 Sécurité de l'agent (chaîne d'approvisionnement)

L'agent disposant de privilèges élevés, il constitue un vecteur de supply-chain potentiel. Les binaires sont signés, le canal de mise à jour est authentifié et l'enrôlement repose sur un jeton à usage unique.

4. Pipeline de données

La télémétrie transite par Apache Kafka, qui découple la collecte du traitement et absorbe les pics. Les événements sont normalisés et enrichis (réputation des hash via VirusTotal et threat intelligence locale) avant corrélation et stockage.

Pipeline de données — de l'endpoint au stockage



Résilience : si le lien Internet tombe, l'agent met en file d'attente localement et rejoue à la reconnexion (aucune perte de données).

Figure 2 — Cheminement de la donnée, de l'endpoint au stockage.

5. Composant 2 — Moteur SIEM et corrélation

Construit sur Wazuh et complété par un moteur de corrélation Python, ce composant reconstitue des chaînes d'attaque multi-étapes et produit une alerte unique enrichie plutôt qu'une multitude d'alertes isolées. Chaque étape est rattachée à une technique MITRE ATT&CK.;

Reconstitution d'une chaîne d'attaque mappée sur MITRE ATT&CK

Corrélation multi-étapes → 1 alerte unique

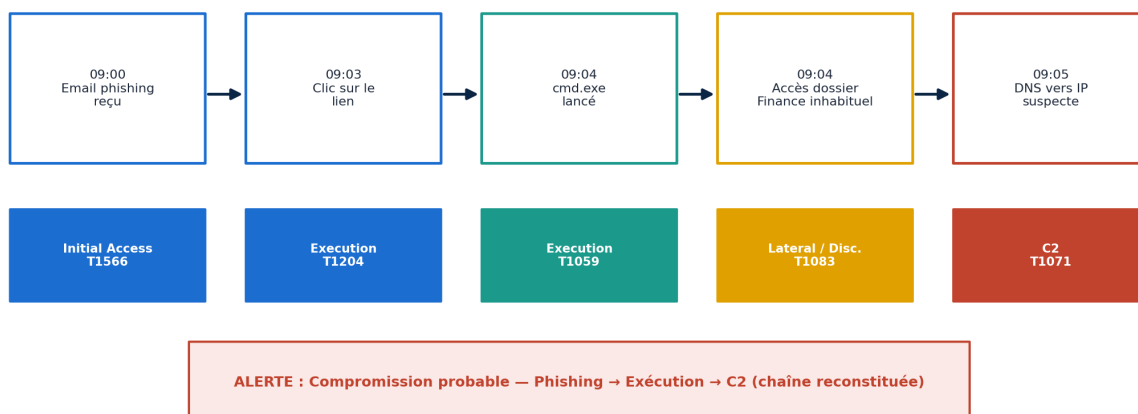


Figure 3 — Exemple de chaîne d'attaque corrélée et cartographiée sur MITRE ATT&CK.;

6. Composant 3 — UEBA (analyse comportementale)

L'UEBA modélise le comportement de référence de chaque entité et signale les écarts (horaires inhabituels, volumes anormaux, accès atypiques) via un score de risque dynamique de 0 à 100.

Choix de modélisation : l'UEBA combine deux approches complémentaires. Isolation Forest assure la détection d'anomalies non supervisée (robuste et peu gourmande), tandis qu'un réseau LSTM capture les motifs séquentiels et temporels du comportement. **Démarrage à froid :** entraînement initial sur jeux de données publics et données synthétiques, puis ré-apprentissage continu sur le terrain.

7. Composant 4 — SOAR (réponse automatisée)

Le SOAR exécute des playbooks déclenchés par les alertes. La réponse est encadrée : seuil de confiance avant toute action destructrice, mode simulation (dry-run), réversibilité (rollback) et validation humaine pour les actions à fort impact (ex. isolation d'un serveur critique).

Incident	Actions du playbook (encadrées)
Ransomware détecté	Isoler le poste (< 30 s) · snapshot mémoire · bloquer l'IP malveillante · notifier le DSI · lancer la restauration depuis sauvegarde.
Phishing cliqué	Identifier les destinataires du même email · supprimer l'email des boîtes · bloquer le domaine en DNS · réinitialiser le mot de passe · alerte de sensibilisation.

➤ Toute action à fort impact passe par un seuil de confiance et/ou une validation, et reste réversible.

8. Composant 5 — Portail, LLM Analyst et notifications

Le portail web (React + Recharts), pensé pour un DSI non-technicien, présente le score de sécurité, les incidents actifs, les postes surveillés et un rapport de conformité ISO 27001, avec des actions rapides. Le **LLM Analyst** (Mistral/Llama via RAG) traduit chaque alerte technique en explication claire en français — il assiste sans jamais décider. Les notifications couvrent les alertes SMS et un rapport de sécurité hebdomadaire.

9. Stockage et souveraineté des données

Le stockage chaud (Elasticsearch pour les logs, TimescaleDB pour les métriques) sert les requêtes récentes ; l'archivage froid, chiffré, est conservé sur une infrastructure **souveraine** nationale. PostgreSQL gère la configuration, les utilisateurs et les tenants. Aucune donnée client sensible n'est stockée sur un cloud étranger — exigence dirimante pour une institution telle que le MINFI.

10. Multi-tenant et sécurité de la plateforme

L'isolation entre clients repose sur des namespaces Kubernetes dédiés et un RBAC strict. La plateforme, qui dispose d'une visibilité privilégiée sur tous ses clients, est elle-même durcie : gestion centralisée des secrets, signature des agents et canal de mise à jour sécurisé limitent le risque de compromission en cascade.

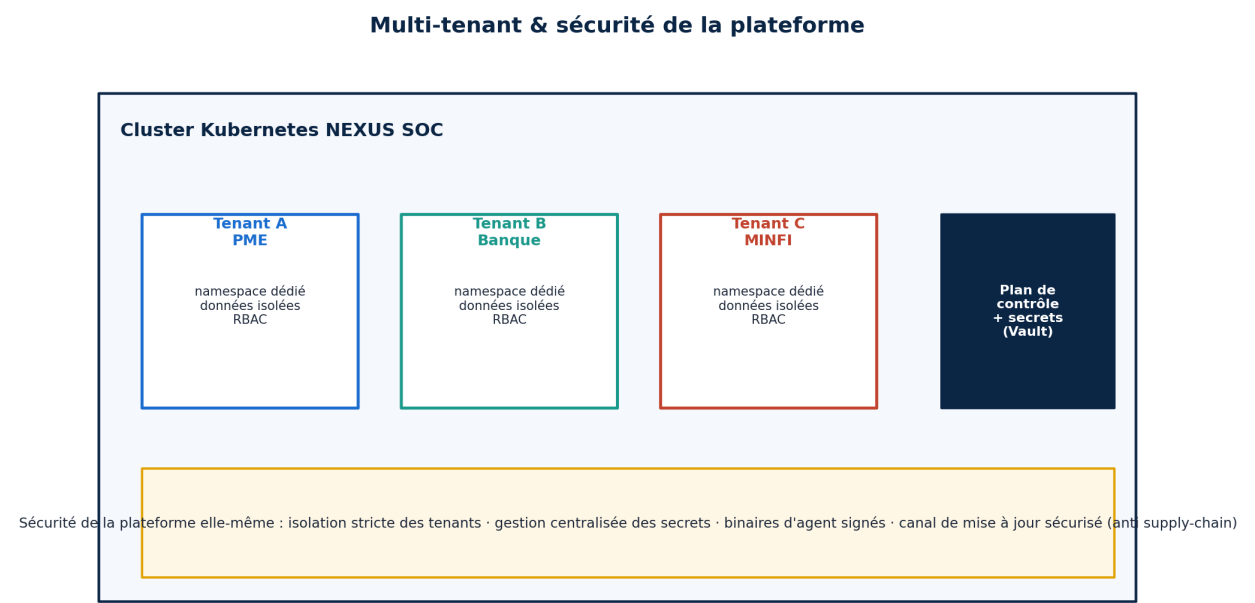


Figure 4 — Isolation multi-tenant et sécurité de la plateforme.

11. Déploiement, CI/CD et supervision

L'infrastructure est décrite en Terraform et déployée via Helm sur Kubernetes ; l'intégration et la livraison continues passent par GitLab CI/CD. La supervision de la plateforme s'appuie sur Prometheus et Grafana (santé des services, latence du pipeline, métriques de détection).

12. Cartographie MITRE ATT&CK; (extrait)

Tactique	Technique (ex.)	Source de détection NEXUS
Initial Access	T1566 Phishing	Corrélation email + clic
Execution	T1059 Command/Script	Agent — création de processus
Persistence	T1547 Boot/Logon	Agent — modifications système

Tactique	Technique (ex.)	Source de détection NEXUS
Discovery	T1083 File/Dir Discovery	Accès fichiers atypique (UEBA)
Exfiltration	T1048 Exfil over protocol	Volume sortant anormal (Modèle 1)
Command & Control	T1071 App Layer Protocol	DNS/IP suspecte (Modèle 1 + TI)